

AUDITORÍA LEGAL INTEGRAL

Portia — Software SaaS de Gestión de Conserjería

Roadmap legal desde la constitución hasta la escala nacional e internacional

Jurisdicción base: Chile
Fecha: 2 de julio de 2026
Versión: 1.0

Alcance y limitación

Este documento es un análisis estructurado para orientar decisiones internas de los fundadores de Portia. No sustituye la asesoría de un abogado habilitado en Chile ni constituye una opinión legal vinculante. Antes de firmar contratos, registrar marca, o levantar inversión, cada sección debe validarse con un estudio jurídico local especializado en derecho societario, protección de datos y tecnología.

Resumen ejecutivo

Portia es un SaaS B2B2C: el cliente que paga es la administradora del edificio, pero el sistema procesa datos personales de terceros que nunca firmaron nada con Portia (residentes, visitantes, conserjes). Esa asimetría — quien paga no es quien está expuesto — es el eje que atraviesa toda esta auditoría: la mayoría del riesgo legal de Portia no está en el contrato comercial, está en la protección de datos de personas que no son el cliente.

El segundo eje es el momento regulatorio: la **Ley 21.719** reemplaza a la Ley 19.628 y entra en vigencia el **1 de diciembre de 2026**, con un año de gracia (solo amonestaciones, sin multas, para PYMEs) hasta diciembre de 2027. Portia nace exactamente en esta ventana de transición, lo que es una oportunidad: se puede construir "cumplimiento por diseño" desde el día uno, en vez de parchear un sistema ya construido bajo la ley antigua.

El tercer eje es la concentración de riesgo en pocas manos: hoy Portia la operan Diego y James, sin sociedad constituida, sin acuerdo de fundadores, sin contrato de trabajo con conserjes reales, y con datos de producción corriendo en Supabase (São Paulo) — es decir, ya existe una transferencia internacional de datos activa antes de que exista una política de privacidad vigente o una empresa que responda legalmente por ella.

1. Constitución de la empresa

1.1 Tipo societario recomendado

Para una startup SaaS chilena con dos fundadores que buscan levantar inversión eventualmente, la recomendación estándar de mercado es la **Sociedad por Acciones (SpA)**, constituida vía "Tu Empresa en un Día" (Ley 20.659) o, si se anticipa inversión extranjera relevante o vesting complejo, directamente por escritura pública ante notario para tener un estatuto a medida desde el inicio.

Estructura	Ventajas	Desventajas
SpA (Sociedad por Acciones)	Flexible: un solo dueño puede administrarla, permite distintas clases de acciones (fundador vs. inversionista), fácil de convertir en S.A. si se necesita abrir a bolsa o traer fondos grandes, capital desde \$1, responsabilidad limitada al capital aportado.	El estatuto "online" de Tu Empresa en un Día es genérico — para vesting, cláusulas de salida y drag-along hay que reemplazarlo por uno redactado a medida (implica notario y más costo inicial).
EIRL (Empresa Individual)	Muy simple y barata.	Un solo titular — inviable con dos fundadores (Diego + James) desde el origen. Descartada.
Ltda. (Sociedad de Responsabilidad Limitada)	Conocida, responsabilidad limitada.	Cambios de socios requieren modificación de escritura con notario cada vez — mal ajuste para vesting progresivo y entrada futura de inversionistas o empleados con stock options. En desuso para startups.
S.A. (Sociedad Anónima)	Estándar para empresas grandes o que cotizan en bolsa.	Sobrerregulada para etapa temprana (directorío obligatorio, juntas formales, memoria anual). Prematura para el tamaño actual de Portia.

Recomendación: SpA con estatuto a medida (no el genérico de Tu Empresa en un Día) desde el momento en que exista dinero de por medio (primer cliente pagado o primera ronda), aunque cueste más al inicio. El motivo es que el estatuto genérico no contempla vesting ni cláusulas de salida, y modificarlo después implica renegociar entre los mismos socios que ya tienen expectativas distintas — es más barato hacerlo bien una vez que corregirlo bajo presión.

1.2 Acuerdo entre fundadores (Founders' Agreement)

Hoy Diego y James trabajan juntos sin ningún documento que regule qué pasa si uno de los dos se va, deja de aportar, o quiere vender su parte. Esto es el riesgo legal más urgente y más barato de resolver de toda la auditoría — un founders' agreement no necesita abogado caro, necesita conversación honesta documentada. Debe cubrir:

- **Roles y dedicación:** qué se espera de cada fundador (full-time, part-time, horas mínimas), y qué pasa si uno reduce su dedicación.
- **Aportes:** capital, tiempo, propiedad intelectual pre-existente (código escrito antes del acuerdo — importante porque parte del código de Portia ya existe).
- **Distribución de acciones inicial**, ligada a vesting (ver 1.3), no a una repartición fija desde el día uno.
- **Toma de decisiones:** qué requiere unanimidad (vender la empresa, endeudarse, contratar deuda, cambiar el giro) vs. qué puede decidir un fundador solo dentro de su área.
- **Resolución de disputas:** mediación obligatoria antes de litigio, cláusula de deadlock (qué pasa si los dos fundadores están 50/50 empatados en una decisión crítica y no se ponen de acuerdo).
- **Confidencialidad y no competencia** mutua mientras dure la sociedad.

1.3 Vesting

El vesting protege a ambos fundadores de que uno se vaya a los 3 meses con el 50% de la empresa. Estándar de mercado (Silicon Valley, replicado en LatAm): **4 años con 1 año de cliff**. Aplicado a Portia:

- Ninguna acción se consolida durante los primeros 12 meses (cliff). Si un fundador se va antes del año, sale con 0% — evita que una salida temprana deje a la empresa con un socio pasivo dueño de una porción grande.
- Al cumplir el año 1, se libera de golpe el 25% de sus acciones ("cliff release").
- El 75% restante se libera mensualmente y en partes iguales durante los siguientes 36 meses.
- **Aceleración por "double trigger":** si la empresa se vende (change of control) Y el fundador es removido o renuncia con causa justificada tras la venta, su vesting se acelera. Esto es estándar y protege al fundador de ser "limpiado" justo después de una adquisición.

Dado que Diego y James ya llevan meses de trabajo, se puede negociar reconocer ese tiempo como "vesting ya corrido" desde una fecha de inicio retroactiva razonable, en vez de reiniciar el reloj — es una decisión de founders, no legal, pero debe quedar escrita.

1.4 Distribución de acciones y derechos de voto

No hay una respuesta "correcta" única — depende de quién originó la idea, quién aporta más código hoy, y expectativas de dedicación futura. Preguntas que el acuerdo debe responder explícitamente, no dejar implícitas:

- ¿50/50, o hay una ponderación por aporte histórico (Diego parece haber escrito la mayoría del código base y coordinado con Claude; James aportó Stage 2 completo y trabaja desde Windows)?

- **Un pool de opciones (10-15%) reservado desde el inicio** para futuros empleados clave — evita tener que diluir solo a los fundadores más adelante.
- **Derechos de voto:** en una SpA de dos socios, lo simple es 1 acción = 1 voto, pero conviene definir **quórum reforzados** (ej. 100% de acuerdo, no solo mayoría) para decisiones irreversibles: vender la empresa, cambiar el giro, endeudarse sobre cierto monto, incorporar un tercer socio.

1.5 Cláusulas de salida (exit provisions)

- **Right of First Refusal (ROFR):** si un fundador quiere vender sus acciones a un tercero, el otro fundador (o la empresa) tiene derecho preferente a comprarlas en las mismas condiciones.
- **Tag-along:** si un fundador vende su participación a un tercero, el otro tiene derecho a vender la suya en las mismas condiciones (evita quedar "atrapado" como socio minoritario de un desconocido).
- **Drag-along:** si una mayoría calificada (ej. ambos fundadores, o fundadores + inversionistas mayoritarios) decide vender el 100% de la empresa, puede forzar a los minoritarios a vender también — esto lo van a exigir los inversionistas en cualquier ronda futura, mejor incluirlo desde el estatuto original que negociarlo después bajo presión de un fondo.
- **Buy-sell / shotgun clause** para el escenario de deadlock irresoluble entre dos socios 50/50: un mecanismo (ej. uno ofrece un precio, el otro elige comprar o vender a ese precio) que evita que la empresa quede paralizada indefinidamente.
- **Cláusula de "bad leaver" vs. "good leaver":** si un fundador se va por causa justificada (renuncia normal) vs. injustificada (incumplimiento grave, competencia desleal), las condiciones de recompra de sus acciones no consolidadas deben ser distintas — un bad leaver no debería poder quedarse con acciones a precio de mercado.

1.6 Protección frente a conflictos entre socios

- Mediación obligatoria previa a cualquier arbitraje o litigio (cláusula escalonada: conversación directa → mediador neutral → arbitraje).
- Arbitraje en vez de tribunales ordinarios para disputas societarias — más rápido y confidencial (relevante si hay inversionistas mirando).
- Cuenta bancaria y acceso a Supabase/Vercel/GitHub con **doble control** para operaciones críticas (ej. transferencias grandes, cambios de dominio, transferencia de propiedad del repositorio) — hoy, según lo visto en la sesión de Vercel, un solo fundador tiene el token con acceso total a producción; eso es un riesgo operacional que se vuelve legal si hay una disputa entre socios.

2. Contratos que Portia debería tener

No todos se necesitan el día uno. La tabla ordena por el momento en que cada uno se vuelve indispensable.

Contrato / documento	Cuándo debe existir	Por qué
Acuerdo de fundadores + vesting	Antes de escribir la primera línea de código compartida (idealmente ayer)	Sin esto, cualquier desacuerdo societario no tiene reglas — ver sección 1
Términos de Servicio	Antes de que cualquier edificio use Portia, aunque sea gratis/piloto	Define qué puede hacer el Cliente, límites de responsabilidad, y qué pasa si algo falla
Política de Privacidad	Antes de recolectar el primer dato de un visitante real	Obligación legal bajo Ley 19.628 hoy, y Ley 21.719 desde dic-2026
DPA (Acuerdo de Tratamiento de Datos)	Antes del primer piloto con datos reales	Formaliza que Portia es "encargado" y el edificio es "responsable" — sin esto, ambos quedan expuestos ante una fiscalización
Contrato de piloto / beta	Para los primeros 1-5 edificios de prueba	Debe dejar explícito que es gratis o con descuento, sin garantías de disponibilidad, y con posibilidad de terminar sin fricción — un piloto mal papeleado se puede interpretar como un contrato comercial completo con todas sus obligaciones
Contrato SaaS / de suscripción comercial	Antes del primer cliente que paga de verdad	Reemplaza al contrato de piloto: define plan, precio, SLA, forma de pago, duración, renovación automática
NDA (mutuo)	Antes de cualquier conversación con inversionistas, proveedores grandes, o candidatos a partner	Protege código, roadmap y datos de clientes antes de compartir información sensible
Contratos laborales (Código del Trabajo)	En el momento en que exista una relación de subordinación y dependencia real, aunque se llame "freelance"	En Chile, si hay horario, instrucciones y exclusividad, es relación laboral aunque el papel diga "honorarios" — mal clasificar expone a demanda

Contrato / documento	Cuándo debe existir	Por qué
		laboral + multas + cotizaciones retroactivas
Contratos de prestación de servicios (honorarios)	Para colaboradores genuinamente independientes (ej. un diseñador puntual, un consultor legal externo)	Válido solo si no hay subordinación real — ver riesgo #7 en la sección 9
Acuerdo de cesión de PI (IP assignment)	Con cada persona que escriba código o diseño para Portia, incluyendo fundadores	Sin esto, el código técnicamente le pertenece a quien lo escribió, no a la empresa — crítico antes de levantar inversión, los fondos siempre lo piden en due diligence
Contratos con proveedores (Supabase, Vercel, dominios)	Ya deberían estar aceptados (son ToS de clic) — revisar sus DPA y SLA antes de escalar	Portia depende de su disponibilidad y de que ellos cumplan protección de datos como subencargados
Acuerdo de confidencialidad con conserjes/administradores piloto	Si van a ver funcionalidades no lanzadas o datos de otros edificios en demos	Evita filtración de roadmap o de datos de terceros durante ventas
Contrato de partner / reseller	Cuando aparezca el primer canal de venta indirecto (ej. una administradora que revende Portia a otros edificios)	Define comisiones, territorio, y quién responde ante el cliente final
Employment Agreement + Stock Option Plan (ESOP)	Cuando se contrate al primer empleado no-fundador	Formaliza compensación con equity de forma legal y fiscalmente ordenada
Acuerdo de accionistas ampliado (con cláusulas de inversionista: liquidation preference, anti-dilución, board seats)	Antes de cerrar la primera ronda de inversión externa (ángel o VC)	El founders' agreement inicial no cubre lo que un inversionista institucional va a exigir

Los tres documentos legales de Portia ya redactados (Términos de Servicio, Política de Privacidad, DPA) cubren el nivel "piloto/lanzamiento" de esta tabla, pero siguen siendo borradores con campos [COMPLETAR] — no están listos para producción real hasta que un abogado los revise y se complete la razón social, el pricing y los plazos de terminación.

3. Protección de datos

3.1 Marco legal aplicable en Chile

- **Ley 19.628** sobre protección de la vida privada — vigente hoy, aplica mientras la Ley 21.719 no entre en régimen.
- **Ley 21.719**, publicada el 13 de diciembre de 2024, entra en vigor el **1 de diciembre de 2026**. Alinea a Chile con estándares tipo GDPR: crea la **Agencia de Protección de Datos Personales**, exige bases de licitud explícitas, derechos ARCO+ (acceso, rectificación, cancelación, oposición, portabilidad, bloqueo), y regula transferencias internacionales.
- **Código del Trabajo** — aplica a los datos de conserjes y administradores como trabajadores/usuarios del sistema (horarios, geolocalización si existiera, evaluación de desempeño vía el sistema).
- **Ley 19.223** sobre delitos informáticos — relevante para el régimen de acceso no autorizado y respuesta ante brechas.
- Durante el primer año de vigencia de la Ley 21.719 (dic-2026 a dic-2027), las **PYMES solo reciben amonestaciones, no multas** — es la ventana para construir cumplimiento sin presión de sanción económica inmediata, pero no exime de responsabilidad civil ni de la obligación de cumplir.

3.2 Obligaciones concretas de Portia

- **Registro de Actividades de Tratamiento (RAT)**: inventario formal de cada tipo de dato que se trata (visitas, encomiendas, novedades, fotos, cuentas), su finalidad, base legal, plazo de retención y medidas de seguridad. No existe hoy — debería crearse como documento vivo, versionado junto al código.
- **Delegado de Protección de Datos (DPO)**: obligatorio si la actividad principal implica tratamiento a gran escala de datos sensibles o monitoreo sistemático a gran escala. Portia probablemente no cruza ese umbral en etapa temprana (no trata datos sensibles deliberadamente, y el volumen por edificio es acotado), pero **sí lo cruzará al escalar a cientos de edificios** — designar un responsable de privacidad (no necesariamente un DPO formal al inicio) desde ya evita una carrera contra el tiempo después.
- **Base de licitud explícita por cada tipo de dato**: para visitas, hoy el diseño ya exige checkbox de consentimiento explícito (correcto). Para conserjes/administradores, la base es ejecución de contrato (laboral o de servicio). Para residentes, probablemente interés legítimo del edificio en su seguridad — pero esto lo debe confirmar un abogado, no es autoevidente.
- **Gestión de derechos ARCO+ end-to-end**: Portia necesita la capacidad técnica real de exportar, corregir o eliminar el dato de una persona específica en todas las tablas donde aparece (visitas, novedades, encomiendas, fotos) — hoy existe borrado automático por retención, pero no un flujo de "un residente pide sus datos y se le entregan en X días".
- **Contrato con Supabase y Vercel como subencargados**: deben tener sus propios DPA con Portia (ambos los ofrecen como parte de sus ToS estándar — hay que revisar que cubran adecuadamente transferencia internacional y notificación de brechas, no asumir que el ToS genérico basta).

- **Notificación de brechas:** a la Agencia y a los afectados dentro de plazos que la ley definirá — Portia necesita un procedimiento interno documentado (quién decide, en cuánto tiempo, a quién se notifica) antes de que ocurra un incidente, no después.

3.3 Consentimientos y permisos necesarios

- **Visitantes:** consentimiento explícito antes de registrar nombre/RUT — ya implementado como checkbox obligatorio, correcto.
- **Residentes:** el edificio (responsable) debe informarles que sus datos de encomiendas/novedades se procesan vía Portia — típicamente vía reglamento de copropiedad o comunicación directa del administrador, no algo que Portia controle directamente pero sí debe exigir contractualmente al Cliente (vía el DPA).
- **Conserjes y administradores:** consentimiento informado sobre auditoría de sus acciones dentro del sistema (quién editó qué, con timestamp) — esto es vigilancia laboral y en Chile tiene límites; debe estar en el contrato laboral o reglamento interno, no ser una sorpresa.
- **Fotos:** las más sensibles — pueden incluir rostros de terceros no registrados (ej. una persona que aparece de fondo en una foto de una encomienda dañada) o patentes de vehículos. Requieren la política de retención más corta y acceso más restringido de todo el sistema.

3.4 Políticas que Portia debe implementar (más allá de la Política de Privacidad pública)

- Política interna de retención y eliminación de datos (ya existe parcialmente documentada en `data-retention.md`, pero debe formalizarse como política, no solo comentario técnico).
- Política de control de acceso (quién dentro del equipo de Portia puede ver datos de producción, y bajo qué justificación — hoy, según lo visto en la sesión de Supabase, el acceso vía MCP directo a producción es amplio y no queda registrado quién hizo qué cambio).
- Política de gestión de subencargados (proceso para evaluar y aprobar cualquier nuevo proveedor que toque datos personales, ej. un servicio de notificaciones push futuro).
- Procedimiento de respuesta a solicitudes ARCO+ (plazos internos, formulario, responsable).

3.5 Riesgos específicos de protección de datos

- **Transferencia internacional ya activa sin cobertura legal formal:** los datos están en Supabase São Paulo desde antes de que exista una Política de Privacidad vigente firmada por ningún cliente — el mayor gap de cumplimiento inmediato.
- **Fotos como categoría de riesgo alto:** pueden capturar datos de personas que nunca dieron consentimiento (terceros de fondo), y su recolección vía la app de escritorio no pasa hoy por el mismo flujo de consentimiento explícito que las visitas.
- **Auditoría interna (quién editó qué) es en sí misma un tratamiento de datos de los conserjes** — mal comunicado, puede generar un reclamo laboral por vigilancia excesiva, independiente de si es técnicamente legal.

- **El administrador (Cliente) puede pedir datos que Portia no debería entregar sin verificar identidad** — ej. un administrador pidiendo el RUT completo de un visitante para un uso no relacionado con la operación del edificio. Portia como encargado no puede simplemente obedecer cualquier instrucción del responsable si excede la finalidad pactada.

4. Seguridad (obligaciones con implicancia legal)

Área	Qué exige la buena práctica / ley	Estado observado en Portia
Backups	Backups regulares, probados (no solo configurados), con copia en ubicación distinta a la de producción	Supabase ofrece backups gestionados — falta documentar frecuencia, retención y una prueba de restauración real
Cifrado	En tránsito (TLS/HTTPS) y en reposo	Cubierto por la infraestructura de Supabase/Vercel — correcto, pero debe declararse explícitamente en la Política de Privacidad y el DPA, no asumirse
Control de accesos	Principio de mínimo privilegio, revisión periódica de quién tiene qué acceso	RLS por edificio implementado en base de datos — bien; pero el acceso de nivel "founder" a producción vía tokens personales (Supabase MCP, Vercel CLI) no tiene rotación ni registro de uso
Auditoría / logs	Registro de accesos y cambios a datos personales, con capacidad de reconstruir quién hizo qué	Existe auditoría de ediciones en novedades/visitas/encomiendas (editado_por, editado_at) — bien encaminado; falta log de accesos de lectura, no solo de escritura
Retención de información	Plazos definidos y justificados por finalidad, no "para siempre por si acaso"	Ya implementado para visitas (30 días); pendiente para encomiendas y novedades (propuesta de 90 días sin confirmar)
Eliminación de datos	Borrado efectivo y verificable, no solo "soft delete" que sigue siendo recuperable	cleanup_old_visitas() automatizado — correcto; revisar si el borrado alcanza también los backups o si ahí persisten más allá del plazo declarado
Respuesta ante incidentes	Procedimiento documentado: detección, contención, notificación, remediación	Existe un <code>incident-response.md</code> referenciado en el DPA — debe convertirse en procedimiento operativo real, no solo documento de referencia

Área	Qué exige la buena práctica / ley	Estado observado en Portia
Recuperación ante desastres (DR)	Plan de qué pasa si Supabase o Vercel caen por horas/días — RTO/RPO definidos	No documentado; para un sistema que un conserje usa para registrar visitas en tiempo real, una caída prolongada tiene impacto de seguridad física del edificio, no solo de negocio

La brecha más relevante en esta sección no es técnica — Portia ya implementó bien varios controles (RLS, auditoría, retención automática). La brecha es que ninguno de estos controles técnicos está todavía **declarado y comprometido contractualmente** ante el Cliente vía el DPA final firmado, lo que significa que hoy son buenas prácticas de ingeniería, no todavía obligaciones legales exigibles.

5. Propiedad intelectual

Activo	Qué hacer	Cuándo
Código fuente	Cesión de PI firmada por cada fundador y colaborador (incluye código escrito con asistencia de IA — dejar constancia de que la empresa es titular del resultado, no la herramienta)	Antes de levantar inversión; idealmente ahora, junto al founders' agreement
Marca "Portia"	Búsqueda de disponibilidad y registro ante INAPI (Instituto Nacional de Propiedad Industrial) en la(s) clase(s) de Niza relevantes (software, clase 42; posiblemente clase 9)	Antes de invertir en marketing serio con ese nombre — registrar tarde permite que un tercero lo registre primero
Logo	Registro como marca mixta (si el diseño es distintivo) además de la marca denominativa	Junto con el registro de marca
Dominio(s)	Verificar titularidad a nombre de la empresa (SpA), no de una persona natural — hoy es común que el dominio quede a nombre de un fundador por comodidad y se olvide transferir	Al momento de registrar el dominio, o corregir cuanto antes si ya está a nombre personal
Base de datos	En Chile no existe un derecho sui generis de bases de datos tan fuerte como en la UE, pero la estructura y compilación pueden protegerse como obra o como secreto comercial	Documentar internamente como secreto comercial (ver siguiente fila) mientras no exista mejor protección
Diseño (UI/UX)	Protegible como obra (derecho de autor) automáticamente al crearse; registro en el Departamento de Derechos Intelectuales (DDI) da fecha cierta y facilita probar autoría en disputa	Opcional pero recomendable antes de mostrarlo ampliamente a inversionistas o competidores potenciales
Copyright del código	Protección automática por el solo hecho de la creación (Chile es parte del Convenio	Registro opcional, recomendable antes de una

Activo	Qué hacer	Cuándo
	de Berna) — no requiere registro para existir, pero el registro en el DDI ayuda a probar fecha y autoría	ronda de inversión (due diligence lo valora)
Secretos comerciales	Definir internamente qué se considera secreto (ej. lógica de pricing, roadmap, ciertos algoritmos) y protegerlo con NDAs y control de acceso — la protección legal de secretos comerciales exige demostrar que se tomaron medidas razonables de confidencialidad	Desde ya — sin medidas de protección demostrables, no hay secreto comercial defendible
Licencias de software propio	Decidir el modelo (propietario cerrado, que es lo esperable para un SaaS comercial) y dejarlo explícito en el repositorio	Antes de que el repositorio sea visible a terceros externos al equipo
Dependencias open source	Auditoría de licencias de cada dependencia (npm, etc.) para verificar que ninguna tenga una licencia copyleft fuerte (ej. AGPL) incompatible con un modelo SaaS propietario	Antes de escalar — hacerlo temprano es barato; descubrir una dependencia AGPL después de tener clientes grandes es caro de resolver

Nota específica: el repositorio de Portia es **público** en GitHub ([yoske7062/conserjeos](https://github.com/yoske7062/conserjeos)). Esto es razonable para colaborar con James y con Claude Code, pero implica que el código — y potencialmente secretos de negocio en commits o en `docs/` — es visible a cualquiera. Conviene decidir conscientemente si eso sigue siendo aceptable a medida que crece el negocio, o si en algún punto pasa a privado.

6. Responsabilidad legal

6.1 De qué puede ser responsable Portia

Escenario	¿De qué respondería Portia?
Caída del sistema	Incumplimiento contractual si hay SLA comprometido; sin SLA (pre-alpha), responsabilidad limitada pero no nula — el Cliente puede alegar incumplimiento de una obligación implícita de diligencia
Pérdida de datos	Responsabilidad contractual ante el Cliente (SaaS agreement) y potencialmente ante la Agencia de Protección de Datos si involucra datos personales sin backup adecuado
Error humano (de un empleado de Portia)	Responsabilidad de la empresa por el hecho de su dependiente (Art. 2320 Código Civil) — Portia responde frente a terceros aunque el error sea de un empleado específico
Registro incorrecto por un conserje	En principio, responsabilidad del Cliente (el conserje es su dependiente, no de Portia) — pero si el error se debe a un bug o mal diseño de la UI que induce el error, la línea se difumina y Portia puede compartir responsabilidad
Eliminación accidental de datos	Si es por un bug de Portia, responsabilidad de Portia; si es una acción del propio Cliente dentro del sistema, responsabilidad limitada de Portia si el sistema tenía las protecciones razonables esperables (ej. confirmaciones, logs)
Accesos no autorizados / cuenta comprometida	Depende de la causa: si es por credenciales débiles del Cliente, responsabilidad del Cliente; si es por una vulnerabilidad del sistema de Portia, responsabilidad de Portia
Filtración de datos (brecha)	Responsabilidad directa de Portia como encargado del tratamiento — debe notificar y puede enfrentar sanción de la Agencia además de la responsabilidad civil frente al Cliente y los titulares afectados
Uso indebido por parte del Cliente	Si el administrador usa Portia para fines no autorizados (ej. vigilancia excesiva de residentes, uso de datos fuera de la finalidad pactada), la responsabilidad primaria es del Cliente como responsable del tratamiento —

Escenario	¿De qué respondería Portia?
	pero Portia debe poder demostrar que exigió y ofreció las herramientas para el uso correcto

6.2 Cómo limitar la responsabilidad contractualmente

- **Cláusula de limitación de responsabilidad** con un tope explícito (estándar de mercado: lo pagado por el Cliente en los últimos 12 meses), excluyendo dolo o culpa grave — un tope total no es válido en Chile si hay dolo o culpa grave de por medio, así que la cláusula debe reconocerlo explícitamente para ser ejecutable.
- **Exclusión expresa de daños indirectos o consecuenciales** (lucro cesante, pérdida de reputación del edificio) — dejar solo el daño directo dentro del tope.
- **"As is" durante pre-alpha**, ya incluido en el borrador de Términos de Servicio — correcto, pero debe evolucionar a un SLA real cuando exista pricing.
- **Indemnidad mutua (mutual indemnification)**: el Cliente indemniza a Portia por el mal uso de los datos de terceros bajo su responsabilidad; Portia indemniza al Cliente por brechas atribuibles a fallas de su sistema.
- **Seguro de responsabilidad civil profesional / cyber insurance**: no es un contrato, pero es la herramienta que hace que estas cláusulas de límite de responsabilidad sean sostenibles en la práctica — vale la pena cotizarlo antes del primer cliente pagado, aunque la prima sea baja al inicio.

7. Implicancias legales de incorporar IA

- **Transparencia:** si Portia usa IA para, por ejemplo, clasificar automáticamente novedades por urgencia o sugerir respuestas, la Ley 21.719 (y la futura regulación de IA que Chile está desarrollando en paralelo) probablemente exigirá informar a los titulares que hay procesamiento automatizado, y darles derecho a solicitar revisión humana si la decisión los afecta significativamente.
- **Prohibición de decisiones automatizadas sin revisión humana** cuando produzcan efectos legales o significativos sobre una persona — ej. si en el futuro Portia usara IA para evaluar el desempeño de un conserje de forma que afecte su empleo, eso requeriría garantías reforzadas.
- **Datos de entrenamiento:** si se entrena o afina un modelo con datos reales de edificios (fotos, novedades, patrones de visitas), eso es un nuevo tratamiento de datos que requiere su propia base de licitud — no se puede asumir que el consentimiento original para "operar el edificio" cubre también "entrenar IA".
- **Proveedores de IA como subencargados adicionales:** si se usa un modelo de terceros (OpenAI, Anthropic, Google) para procesar datos personales de Portia, ese proveedor entra a la cadena de subencargados del DPA y debe evaluarse igual que Supabase o Vercel — incluyendo dónde procesan los datos geográficamente.
- **Riesgo de sesgo:** cualquier IA que priorice o clasifique (ej. "qué incidentes son más urgentes") puede introducir sesgos no evidentes — conviene documentar cómo se probó el modelo antes de desplegarlo, como evidencia de diligencia debida.
- **Recomendación:** cuando se diseñe la primera funcionalidad de IA, agregar una sección específica al DPA y a la Política de Privacidad antes de lanzarla, no después — es mucho más barato incluirlo desde el borrador que enmendar un contrato ya firmado con decenas de clientes.

8. Checklist de cumplimiento por prioridad

Obligatorio antes de lanzar (aunque sea piloto gratuito)

- Política de Privacidad publicada y accesible (borrador ya existe, falta completar campos y revisión de abogado)
- Términos de Servicio / de piloto aceptados explícitamente por cada edificio piloto
- DPA firmado con cada edificio piloto que use datos reales
- Consentimiento explícito de visitantes ya implementado — verificar que cubra también fotos
- Acuerdo de fundadores + vesting, aunque sea informal por ahora
- Backups verificados con al menos una prueba de restauración

Obligatorio antes de tener clientes pagados

- SpA constituida formalmente, con estatuto propio (no genérico)
- Cesión de PI firmada por ambos fundadores
- Contrato SaaS comercial (reemplaza al de piloto), con pricing y SLA definidos
- RAT (Registro de Actividades de Tratamiento) documentado
- Boleta/factura electrónica habilitada en el SII
- Seguro de responsabilidad civil / cyber cotizado, idealmente contratado
- Procedimiento de respuesta a incidentes operativo, no solo documentado

Obligatorio antes de crecer (decenas de clientes, primer empleado)

- Registro de marca ante INAPI
- Primer contrato laboral formal (Código del Trabajo) si se contrata al primer empleado no-fundador
- ESOP / plan de opciones para empleados
- Designación formal de responsable de privacidad (camino a DPO)
- Auditoría de licencias open source de las dependencias
- Plan de recuperación ante desastres (DR) documentado con RTO/RPO
- Cumplimiento pleno de la Ley 21.719 (vigente desde dic-2026) — DPA con todos los subencargados, incluida cláusula de transferencia internacional

Recomendado

- Registro de copyright del código y diseño en el DDI
- Certificación o al menos alineación con un estándar de seguridad reconocido (ej. controles tipo ISO 27001, sin necesariamente certificarse aún)
- Cyber insurance con cobertura ampliada
- Auditoría de seguridad externa (pentest) antes de una ronda de inversión grande

Opcional (por ahora)

- Registro internacional de marca (Protocolo de Madrid) — solo relevante si hay plan concreto de expansión fuera de Chile
- Certificación ISO 27001 formal — costosa y prematura para el tamaño actual
- DPO dedicado de tiempo completo — hasta que el volumen de datos lo justifique

9. Los 20 mayores riesgos legales, ordenados por impacto

#	Riesgo	Nivel	Prob.	Consecuencia	Mitigación
1	Brecha de seguridad con filtración de datos personales (fotos, RUT)	Crítico	Media	Sanción de la Agencia, demandas de titulares, pérdida de confianza de todos los clientes a la vez	DPA robusto, cifrado, control de accesos, seguro cyber, procedimiento de respuesta a incidentes probado
2	No existir sociedad constituida mientras ya se procesan datos reales	Crítico	Alta (ya está ocurriendo)	Los fundadores responden con patrimonio personal por cualquier reclamo hasta que exista SpA	Constituir SpA antes del primer piloto con datos reales, o inmediatamente
3	Ausencia de acuerdo de fundadores con vesting	Crítico	Media	Disputa societaria que paraliza la empresa o fuerza una salida injusta de un fundador	Firmar founders' agreement + vesting ahora, retroactivo si es necesario
4	Transferencia internacional de datos (Supabase Brasil) sin base legal declarada	Alto	Alta (ya está ocurriendo)	Incumplimiento de Ley 21.719 desde su entrada en vigencia; exposición inmediata en cuanto haya fiscalización	Declarar explícitamente la transferencia en la Política de Privacidad y DPA, evaluar si se requiere garantía adicional
5	Mala clasificación laboral de un colaborador como "honorarios" cuando hay subordinación real	Alto	Media	Demanda laboral, multas, cotizaciones retroactivas, y el vínculo se "transforma" en indefinido con indemnización	Evaluar cada colaborador contra los criterios de subordinación del Código del Trabajo antes de definir el tipo de contrato
6	Código sin cesión de PI formal de los fundadores	Alto	Media	Un fundador que se va podría alegar titularidad parcial del código; bloquea due diligence de inversión	Firmar cesión de PI ahora, no esperar a la ronda de inversión
7	Fotos capturando a terceros sin consentimiento	Alto	Alta	Reclamo de un tercero que nunca fue informado ni dio consentimiento	Política de retención más corta para fotos, minimización (blur automático si es viable), aviso

#	Riesgo	Nivel	Prob.	Consecuencia	Mitigación
	(personas de fondo, patentes)				reforzado en Política de Privacidad
8	SLA inexistente hoy pero implícitamente esperado por clientes que empiezan a pagar	Medio-Alto	Media	Reclamo por incumplimiento cuando el sistema cae, sin marco contractual claro que lo limite	Definir SLA explícito antes de cobrar, aunque sea modesto (ej. 99% mensual, sin penalidad los primeros meses)
9	Repositorio público con posible información sensible en commits o docs	Medio-Alto	Media	Exposición de secretos comerciales, credenciales históricas, o datos de arquitectura útiles para un atacante	Auditar historial de commits, mover documentos sensibles a un repo privado o carpeta no versionada
10	Marca "Portia" no registrada	Medio-Alto	Media	Un tercero registra el nombre primero y Portia debe cambiar de marca en plena operación	Registrar en INAPI antes de invertir en marketing
11	Dominio a nombre de una persona natural, no de la empresa	Medio	Media	Disputa de titularidad si esa persona deja la empresa en malos términos	Verificar y transferir titularidad a la SpA
12	Dependencia open source con licencia copyleft incompatible (ej. AGPL)	Medio	Baja-Media	Obligación legal de liberar código propietario, o litigio de la comunidad open source	Auditoría de licencias antes de escalar
13	Acceso de founder-level a producción sin rotación de credenciales ni logs de uso	Medio	Media	En una disputa societaria, o ante una brecha, no hay forma de reconstruir quién hizo qué	Rotación periódica de tokens, logs de acceso, principio de mínimo privilegio incluso entre fundadores
14	Consentimiento de residentes delegado al edificio sin verificación de que realmente ocurre	Medio	Media	Portia asume que el Cliente informó a los residentes, pero si no lo hizo, Portia comparte exposición como encargado	Exigir contractualmente evidencia de que el Cliente cumplió su obligación de informar (vía DPA)

#	Riesgo	Nivel	Prob.	Consecuencia	Mitigación
15	Ausencia de plan de recuperación ante desastres (DR)	Medio	Baja	Caída prolongada de Supabase/Vercel deja a conserjes sin sistema por horas o días, con impacto en seguridad física del edificio	Documentar RTO/RPO, evaluar plan de contingencia manual para el conserje
16	Auditoría interna de acciones de conserjes interpretada como vigilancia laboral excesiva	Medio	Baja-Media	Reclamo laboral o ante la Dirección del Trabajo por vigilancia desproporcionada	Comunicar explícitamente el alcance de la auditoría en el contrato/reglamento laboral, limitarla a lo necesario para la operación
17	Piloto gratuito tratado informalmente sin ningún documento firmado	Medio	Alta	Sin marco contractual, un edificio piloto insatisfecho puede reclamar como si fuera cliente pagado con expectativas contractuales	Contrato de piloto simple, aunque sea de una página, firmado antes de cargar datos reales
18	Futuras integraciones con sistemas de terceros (control de acceso, cámaras) sin evaluar sus propios riesgos de datos	Medio	Baja (a futuro)	Portia hereda exposición de la seguridad del tercero integrado	Debida diligencia de seguridad antes de cada integración nueva, cláusula de responsabilidad clara
19	IA futura entrenada con datos reales sin nueva base de licitud	Medio	Baja (a futuro)	Tratamiento de datos no autorizado para ese fin específico	Evaluar y documentar base legal antes de cualquier entrenamiento con datos de producción
20	Falta de seguro de responsabilidad civil / cyber	Bajo-Medio	Media	Cualquier reclamo grande (brecha, caída prolongada) recae 100% sobre el patrimonio de la empresa/fundadores	Cotizar e idealmente contratar antes del primer cliente pagado grande

10. Roadmap legal por etapa

MVP (piloto interno / primeros edificios de prueba)

- Founders' agreement + vesting firmado
- Política de Privacidad y Términos de Servicio (borrador ya existe) completados y publicados
- Contrato de piloto de una página por cada edificio de prueba
- Consentimiento explícito de visitantes verificado en el flujo real

Primer cliente (paga de verdad)

- SpA constituida con estatuto propio
- Contrato SaaS comercial con pricing y SLA mínimo definido
- DPA firmado con ese cliente
- Cesión de PI de ambos fundadores formalizada
- Boleta electrónica habilitada

10 clientes

- RAT documentado y mantenido como proceso, no como evento único
- Procedimiento de respuesta a incidentes probado con un simulacro
- Backups con prueba de restauración documentada
- Seguro de responsabilidad civil / cyber cotizado y evaluado
- Registro de marca iniciado en INAPI

100 clientes

- Primer(os) empleado(s) no-fundador con contrato laboral formal + ESOP
- Responsable de privacidad designado formalmente (camino a DPO)
- Auditoría de licencias open source completada
- Plan de recuperación ante desastres (DR) documentado y probado
- Cumplimiento pleno Ley 21.719 (vigente desde dic-2026): DPA con todos los subencargados, transferencias internacionales declaradas
- Evaluación de si el repositorio debe pasar a privado

1.000 clientes

- Pentest / auditoría de seguridad externa recurrente
- Preparación de due diligence legal completa para ronda de inversión institucional (si aplica)
- Acuerdo de accionistas ampliado con cláusulas de inversionista
- Evaluación de necesidad de DPO dedicado de tiempo completo
- Políticas internas de RR.HH. formalizadas (más allá de contratos individuales)

Expansión internacional

- Análisis país por país: la Ley 21.719 chilena no protege a Portia fuera de Chile — cada mercado nuevo (ej. Perú, México, Colombia) tiene su propia ley de protección de datos que puede exigir un DPO local, un representante local, o registro ante su propia agencia
- Evaluar si conviene constituir entidad local en cada país o operar como matriz chilena que factura al extranjero
- Registro de marca internacional (Protocolo de Madrid) para los mercados objetivo
- Adaptación de Términos de Servicio y Política de Privacidad por jurisdicción (no basta traducir, cambian las obligaciones)
- Revisión de si la infraestructura (Supabase São Paulo) sigue siendo adecuada o conviene multi-región por mercado

11. Crítica honesta

Esta sección es deliberadamente incómoda. El objetivo no es validar lo que ya se hizo, sino encontrar lo que se está pasando por alto antes de que se vuelva costoso.

La empresa no existe legalmente, pero el producto ya opera con datos reales

Este es el problema más grave de todos y el más fácil de arreglar. Diego y James están operando un sistema que procesa datos de terceros (visitantes, residentes) sin que exista una persona jurídica que responda por ello. Si algo sale mal hoy — una filtración, un reclamo — la exposición recae sobre el patrimonio personal de los fundadores, no sobre una SpA. Esto debería resolverse antes que cualquier otra cosa en esta lista, incluso antes de seguir agregando funcionalidades.

Los documentos legales existentes son un buen borrador, pero se están tratando como si fueran suficientes

Los tres documentos (Términos, Privacidad, DPA) están bien estructurados y muestran conciencia real de los temas correctos (roles responsable/encargado, Ley 21.719, retención). Pero siguen teniendo campos [COMPLETAR] en cláusulas centrales: quién responde legalmente (razón social), cuál es el plazo de terminación, cuál es el tope de responsabilidad. Publicarlos así, aunque sea para un piloto "gratis", da una falsa sensación de cobertura legal que no existe todavía.

El acceso a producción está concentrado sin control cruzado

Durante esta misma sesión de trabajo se usó un token personal de Vercel con acceso total para modificar configuración de producción, y se usó acceso directo a Supabase para aplicar cambios de esquema. Esto es normal en una startup de dos personas, pero es exactamente el tipo de práctica que se vuelve un problema legal si algún día hay una disputa entre los fundadores, o si se necesita demostrar ante un auditor o un inversionista quién tuvo acceso a qué y cuándo. No hay que sobreingenierizar esto ahora, pero sí empezar a registrar quién usa qué acceso.

El modelo de negocio (B2B2C) subestima a quién protege la ley

Portia está diseñado pensando en el administrador como cliente, lo cual es correcto comercialmente. Pero legalmente, la mayor parte de la exposición no viene del administrador — viene de los residentes y visitantes que nunca aceptaron nada directamente con Portia. La Ley 21.719 no distingue entre "quién paga" y "quién está expuesto"; protege a la persona cuyo dato se trata. El roadmap legal de Portia debería estar organizado alrededor de esa asimetría, no solo alrededor de crecer clientes pagados.

No hay nada dicho sobre qué pasa si Portia deja de operar

Ningún documento actual cubre qué pasa con los datos de un edificio si Portia cierra, es adquirida, o simplemente deja de dar soporte a un cliente. Esto parece un problema "para más adelante", pero es exactamente el tipo de cláusula que un administrador cauteloso (o su propio abogado) va a preguntar antes de firmar, sobre todo tratándose de un producto pre-alpha de una startup de dos personas. Tener una respuesta clara (ej. exportación garantizada de datos en X días, código depositado en escrow si la empresa cierra) es una ventaja de venta, no solo una obligación legal.

El uso de IA (Claude Code) para operar la infraestructura de producción no está evaluado como riesgo en sí mismo

Portia usa asistencia de IA no solo para escribir código sino para ejecutar cambios directos en producción (base de datos, despliegues). Esto es eficiente, pero introduce una pregunta que ningún documento actual responde: ¿quién es responsable si una acción ejecutada por o a través de una IA causa un daño (ej. un cambio de esquema mal aplicado, una configuración de producción incorrecta)? La respuesta legal es que la responsabilidad sigue siendo de la empresa que opera la herramienta, no de la IA — pero eso significa que los mismos controles de acceso, revisión y aprobación que se exigirían a un empleado humano deberían aplicar a las acciones ejecutadas con asistencia de IA sobre producción, y hoy no aplican de forma sistemática.

Aspecto no mencionado por Diego que sí es relevante: continuidad del servicio para un edificio en litigio o quiebra de la administradora

Si la administradora que contrató Portia (el Cliente) entra en disputa legal, cambia de administración, o el edificio cambia de administradora, ¿quién es dueño de los datos históricos del edificio — el edificio (la comunidad de copropietarios) o la administradora que firmó el contrato? Este es un problema real y frecuente en la industria de administración de edificios en Chile (cambios de administradora son comunes y a veces conflictivos), y el diseño actual de Portia no distingue entre "el edificio" como entidad continua y "la administradora" como cliente que paga en un momento dado. Vale la pena resolver esto en el contrato SaaS antes de que ocurra el primer cambio de administradora de un cliente real.

Nota final

Este documento es un mapa de lo que hay que resolver, no una solución legal en sí misma. La recomendación concreta es: resolver los tres riesgos críticos de la sección 9 (constitución de la empresa, acuerdo de fundadores, transferencia internacional de datos) en las próximas semanas, y llevar este documento completo a un abogado chileno especializado en protección de datos y derecho societario de startups para validación antes de tomar cualquier decisión basada en él.